Universidad Técnica Nacional

Pruebas de Software (ISW-622)

Informe técnico de pruebas de seguridad

Laboratorio de expedientes académicos: del requisito verificable a la evidencia y el dictamen de liberación

Curso	Pruebas de Software
Código del curso	ISW-622
Unidad	IV · Creación de Pruebas de Seguridad
Integrantes	Wilberth Guillén Aguilar Jania Hernández Dormuz
Grupo	Sábados
Fecha de entrega	30 de octubre de 2026
Proyecto	laboratorio-pruebas-seguridad
Versión del proyecto	0.2 · corte del bloque de Wilberth (commit 8e98b14, rama wil)
Repositorio	https://github.com/WGuillenDev/laboratorio-pruebas-seguridad

Estado del documento: versión parcial. Contiene el trabajo completo del bloque de Wilberth y deja identificadas, con su diseño, las actividades asignadas a Jania. Las secciones marcadas como **Pendiente (Jania)** se completarán antes de la entrega final.

Contenido

Contenido 2
1. Introducción y alcance 4
1.1 Propósito 4
1.2 Alcance 4
1.3 Entorno de laboratorio 4
1.4 Reparto del trabajo 4
2. Activos, flujo de datos y amenazas 5
2.1 Inventario de activos 5
2.2 Flujo de datos 5
2.3 Amenazas priorizadas 6
3. Requisitos, criterios de aceptación y trazabilidad 7
3.1 Requisitos de seguridad verificables 7
3.2 Criterios de aceptación (Dado–Cuando–Entonces) 7
3.3 Matriz requisito – riesgo – caso de prueba 8
4. Diseño de los casos de prueba 8
4.1 Resumen de los 12 casos 8
4.2 Fichas de los casos (plantilla A.1) 10
5. Ciclos TDD rojo – verde – refactor 15
5.1 Ciclo 1 · Acceso indebido a expediente ajeno (TC-04, SEC-01, H-01) 15
5.2 Ciclo 2 · Validez de sesión (TC-08, SEC-03, H-02) — Pendiente (Jania) 16
6. Ejecución en laboratorio 16
6.1 Pruebas automatizadas 16
6.2 Pruebas manuales por la API 17
6.3 Revisión estática del código (SAST manual) 17
6.4 Corrección y regresión 18
7. Revisiones, usabilidad y reproducibilidad 18
7.1 Acta de inspección cruzada — Pendiente (Jania) 18
7.2 Revisión de las propias pruebas 20
7.3 Usabilidad de los mensajes del control 20
7.4 Ajustes para mantenimiento y diagnóstico 20

7.5 Prueba de reproducibilidad con el README — Pendiente (Jania) 21
8. Registro de hallazgos 21
8.1 Falsos positivos y fallos de la propia prueba 22
9. Indicadores, dictamen de liberación y riesgo residual 22
9.1 Estado consolidado de los 12 casos 22
9.2 Indicadores calculados 22
9.3 Dictamen 23
9.4 Defectos abiertos, limitaciones y riesgo residual 23
10. Aportes del equipo y uso de IA 24
Anexo A. Evidencias visuales 25
A.1 Ciclo TDD 1 25
A.2 Verificación del bloque y pruebas HTTP 26
Anexo B. Índice de evidencias 27

1. Introducción y alcance

1.1 Propósito

Este informe documenta una campaña breve de pruebas de seguridad sobre el laboratorio local de expedientes académicos proporcionado por el docente. Se identifican activos y amenazas, se redactan requisitos verificables, se diseñan y automatizan casos de prueba aplicando TDD, se inspecciona el código y se justifica una decisión de liberación con base en evidencias reproducibles.

1.2 Alcance

Dentro del alcance: lectura de expedientes, modificación de notas, validez de sesiones (ausente, desconocida, revocada, expirada), confidencialidad de las respuestas de error, validación de notas y auditoría de operaciones. Se prueban la lógica de negocio (src/lab.py) y la API HTTP local (servidor.py).

Fuera del alcance: sistemas reales de la universidad, autenticación de producción, despliegue, rendimiento, carga, concurrencia y persistencia externa. Todos los usuarios, tokens y expedientes son sintéticos.

1.3 Entorno de laboratorio

Elemento	Valor
Sistema operativo	Windows 11 (equipo personal)
Lenguaje y pruebas	Python 3.14.7 · unittest (biblioteca estándar, sin paquetes externos)
Cliente HTTP	curl.exe y PowerShell contra http://127.0.0.1:8765
Datos iniciales	Expediente 101: Ana, sede Central, nota 82 · Expediente 202: Luis, sede Pacífico, nota 91
Cuentas sintéticas	lab-ana, lab-luis (estudiantes) · lab-maria (docente Central) · lab-pedro (docente Pacífico) · lab-admin (administrador) · lab-vencida (sesión expirada de Ana)
Restablecer datos	Reiniciar servidor.py (HTTP) · setUp() crea un estado nuevo por prueba (unittest)

1.4 Reparto del trabajo

El equipo dividió los 12 casos en dos bloques de seis para que cada integrante diseñe, automatice, ejecute y documente su parte, y revise la del otro (inspección cruzada).

Integrante	Casos	Controles y entregables
Wilberth Guillén	TC-01, TC-03, TC-04, TC-05, TC-07, TC-12	Autorización de lectura por rol/sede, validación de notas, auditoría de lecturas, ciclo TDD 1, pruebas HTTP TC-05 y TC-12, revisión estática, README, matriz e informe
Jania Hernández	TC-02, TC-06, TC-08, TC-09, TC-10, TC-11	Sesiones revocadas/expiradas, autorización de escritura por sede, auditoría de actualizaciones, ciclo TDD 2, integración HTTP automatizada (TC-10/11), pruebas HTTP TC-06 y TC-09
Ambos	—	Inspección cruzada, prueba de reproducibilidad con el README, corridas finales y dictamen

2. Activos, flujo de datos y amenazas

2.1 Inventario de activos

ID	Activo	Dónde reside	Propiedad a proteger
A-01	Expediente académico (id, titular, sede)	estado['expedientes']	Confidencialidad
A-02	Nota académica (0–100)	campo nota del expediente	Integridad y confidencialidad
A-03	Sesiones y tokens sintéticos (revocada / expirada)	estado['sesiones']	Validez del acceso
A-04	Política de permisos por rol, identidad y sede	USUARIOS y funciones de autorización	Autorización
A-05	Bitácora de auditoría	estado['auditoria']	Trazabilidad; no contener credenciales
A-06	Respuestas de la API (cuerpo y código HTTP)	servidor.py → cliente	No divulgar información protegida

2.2 Flujo de datos

1. El cliente (curl, PowerShell o prueba automatizada) envía la solicitud con el encabezado Authorization: Bearer <token>, la ruta /expedientes/<id> y, para cambios, un cuerpo JSON {"nota": n}.

2. servidor.py extrae token, identificador y cuerpo; limita el tamaño (1024 bytes) y valida que el JSON sea un objeto.
3. src/lab.py autentica la sesión, busca el expediente, aplica la política de autorización y valida la nota.
4. Si la operación es permitida, se lee o modifica el estado en memoria y se agrega un evento a la auditoría.
5. El servidor responde con código HTTP y JSON (Cache-Control: no-store) al cliente.

Frontera de confianza: todo lo que llega del cliente (token, identificador y nota) es no confiable. Las decisiones de seguridad deben tomarse en src/lab.py; el servidor solo transporta. Por eso las pruebas unitarias verifican la lógica y las pruebas HTTP verifican que el comportamiento se mantiene a través de la API.

2.3 Amenazas priorizadas

La prioridad combina la probabilidad (facilidad para un usuario con cuenta válida) y el impacto sobre el activo.

ID	Actor y acción de abuso	Activo	Impacto	P / I	Prioridad razonada
R-01	Estudiante cambia el id de la URL para leer otro expediente; docente lee expedientes de otra sede	A-01, A-02, A-04	Divulgación de notas de terceros	Alta / Alta	**Alta**: basta editar la URL con una sesión válida (IDOR)
R-02	Docente modifica una nota de otra sede; estudiante o administrador intenta cambiar notas	A-02, A-04	Calificaciones alteradas sin autorización	Media / Alta	**Alta**: rompe la integridad y la separación de funciones
R-03	Portador reutiliza una sesión revocada o vencida, o usa un token inventado	A-03, A-01	Acceso que ya debía haber terminado	Media / Alta	**Alta**: anula el cierre de sesión
R-04	Docente autorizado envía una nota fuera de 0–100, booleana o no numérica	A-02	Datos académicos inválidos persistidos	Media / Media	**Media**: requiere docente autorizado, pero corrompe el registro

ID	Actor y acción de abuso	Activo	Impacto	P / I	Prioridad razonada
R-05	Persona con acceso a la bitácora extrae tokens o no puede atribuir una acción	A-05, A-03	Reutilización de sesiones; falta de no repudio	Baja / Alta	**Media**: requiere acceso a registros; el daño es amplio

3. Requisitos, criterios de aceptación y trazabilidad

3.1 Requisitos de seguridad verificables

ID	Categoría	Requisito observable (oráculo)
SEC-01	Autorización (lectura)	Con sesión válida, un estudiante lee solo su expediente, un docente solo los de su sede y el administrador los de ambas sedes. Lectura permitida → 200 con los datos exactos. Cualquier otra lectura → 403.
SEC-02	Integridad (cambio de nota)	Solo un docente de la misma sede del expediente puede cambiar la nota (200 y valor persistido). Estudiante, administrador y docente de otra sede → 403 y el expediente queda idéntico.
SEC-03	Sesiones	Una solicitud con sesión ausente, desconocida, revocada o expirada → 401, sin datos protegidos y sin cambios.
SEC-04	Validación de entrada	Solo se aceptan notas numéricas (int/float, no bool) dentro de [0, 100] inclusive. Valores fuera de rango, NaN, infinitos o de otro tipo → 400 sin persistir.
SEC-05	Confidencialidad	Toda respuesta de denegación (401/403) omite id, estudiante, sede y nota, y no identifica al titular. Una operación rechazada no modifica ningún expediente.
SEC-06	Trazabilidad	Cada lectura y cambio permitido registra acción, usuario e id de expediente, y nunca almacena el token.

3.2 Criterios de aceptación (Dado–Cuando–Entonces)

CA-01 (SEC-01, SEC-05). **Dado** Ana, estudiante con sesión válida, y el expediente 202 de Luis, **cuando** solicita GET /expedientes/202, **entonces** recibe 403 sin id, estudiante, sede ni nota, y los expedientes quedan intactos.

CA-02 (SEC-02, SEC-05). **Dado** María, docente de Central, y el expediente 202 de Pacífico con nota 91, **cuando** envía POST /expedientes/202/nota con {"nota": 70}, **entonces** recibe 403 y el expediente 202 conserva la nota 91 y sus demás campos.

CA-03 (SEC-03). **Dado** una sesión de Ana revocada mediante POST /sesiones/revocar, **cuando** solicita su propio expediente 101, **entonces** recibe 401 sin datos protegidos.

CA-04 (SEC-04). **Dado** María con sesión válida y el expediente 101 con nota 82, **cuando** envía -1, 101, "ochenta", true o un entero de 401 cifras, **entonces** recibe 400 en cada caso y la nota sigue siendo 82; en cambio, 0 y 100 se aceptan y persisten.

3.3 Matriz requisito – riesgo – caso de prueba

Requisito	Riesgos	Casos de prueba	Evidencia esperada
SEC-01	R-01	TC-01, TC-03, TC-04, TC-05	Salida unittest; registro HTTP antes/después
SEC-02	R-02	TC-02, TC-06, TC-07, TC-10, TC-11	Respuesta 200/403 y comparación del estado
SEC-03	R-03	TC-08, TC-09	Registros TDD 2 y solicitudes HTTP con 401
SEC-04	R-04	TC-10, TC-11, TC-12	Respuestas 200/400 y nota persistida o intacta
SEC-05	R-01, R-02, R-03	TC-04, TC-05, TC-06, TC-07, TC-08, TC-09	Cuerpo sin campos protegidos; estado intacto
SEC-06	R-05	TC-01, TC-02, TC-03, TC-10, TC-11	Evento de auditoría con usuario y sin token

El detalle completo de cada caso (precondiciones, entradas, pasos, resultado y evidencia real) está en el anexo matriz_trazabilidad.csv, que usa los mismos identificadores que este informe y que hallazgos.csv.

4. Diseño de los casos de prueba

4.1 Resumen de los 12 casos

Se diseñaron 12 casos distintos: **3 positivos, 6 negativos y 3 de frontera**. Ocho se automatizan (seis de unidad y dos de integración HTTP) y cuatro se ejecutan manualmente por HTTP. Las variantes de datos dentro de un caso no se cuentan como casos adicionales.

ID	Tipo	Escenario	SEC	Modalidad	R.	Estado
TC-01	Positivo	Ana lee su expediente 101	01, 06	Unidad	W	Aprobado
TC-02	Positivo	María cambia la nota del 101 (su sede)	02, 06	Unidad	J	No ejecutado
TC-03	Positivo	Administrador lee 101 y 202	01, 06	Unidad	W	Aprobado
TC-04	Negativo	Ana intenta leer el 202 de Luis (TDD 1)	01, 05	Unidad	W	Aprobado
TC-05	Negativo	María intenta leer el 202 (otra sede)	01, 05	HTTP manual	W	Aprobado
TC-06	Negativo	María intenta cambiar la nota del 202	02, 05	HTTP manual	J	No ejecutado
TC-07	Negativo	Estudiante y administrador intentan cambiar notas	02, 05	Unidad	W	Aprobado
TC-08	Negativo	Sesión revocada / ausente / desconocida (TDD 2)	03, 05	Unidad	J	Fallido
TC-09	Negativo	Sesión expirada lee y modifica	03, 05	HTTP manual	J	No ejecutado
TC-10	Frontera	Nota 0 (límite inferior válido)	02, 04, 06	Integración	J	No ejecutado
TC-11	Frontera	Nota 100 (límite superior válido)	02, 04, 06	Integración	J	No ejecutado
TC-12	Frontera	Notas -1, 101, texto, true, entero enorme	04	HTTP manual	W	Aprobado

R. = responsable (W = Wilberth, J = Jania). Automatizados: TC-01, 02, 03, 04, 07, 08 (unidad) y TC-10, 11 (integración) = 8. Manuales HTTP: TC-05 (acceso entre sedes), TC-06, TC-09 y TC-12 (entrada inválida) = 4.

4.2 Fichas de los casos (plantilla A.1)

Todos los comandos se ejecutan desde entrega/laboratorio_seguridad. Cada prueba unitaria inicia con estado_inicial() y guarda una copia profunda de los expedientes para comparar el estado después de la operación.

TC-01 · Estudiante lee su propio expediente

Identificación	TC-01 / SEC-01, SEC-06 / R-01, R-05 / prioridad alta
Objetivo	Confirmar que el control no bloquea el acceso legítimo y que la lectura queda auditada sin token.
Precondiciones	Estado nuevo; Ana (estudiante, Central) con sesión válida; 101 con nota 82.
Datos / pasos	leer_expediente(estado, 'lab-ana', '101') · comando: python -m unittest discover -s tests -k tc01 -v
Oráculo	200; respuesta idéntica al expediente 101; expedientes sin cambios; un evento {accion: lectura, usuario: ana, id: 101} sin token.
Observado	200 y todas las aserciones correctas en dos corridas limpias (versión 8e98b14).
Resultado	**Aprobado** · Wilberth · evidencias/wilberth_unidad_corrida1.txt y _corrida2.txt

TC-02 · Docente cambia una nota de su sede

Identificación	TC-02 / SEC-02, SEC-04, SEC-06 / R-02, R-04, R-05 / alta
Objetivo	Verificar que la operación legítima persiste y se audita sin token.
Precondiciones	Estado nuevo; María (docente, Central); 101 = 82 y 202 = 91.
Datos / pasos	actualizar_nota(estado, 'lab-maria', '101', 85); leer después el estado.
Oráculo	200; nota 85 persistida en 101; 202 intacto; evento {actualizacion, maria, 101} sin token.
Observado	El ejemplo original solo verifica 200 y la nota devuelta; falta ampliar persistencia y auditoría.
Resultado	**No ejecutado** (diseño completo) · Pendiente (Jania)

TC-03 · Administrador lee expedientes de ambas sedes

Identificación	TC-03 / SEC-01, SEC-06 / R-01, R-05 / alta
Objetivo	Confirmar el alcance global de lectura del administrador sin alterar datos.
Precondiciones	Estado nuevo; lab-admin válido; expedientes 101 y 202.
Datos / pasos	leer_expediente con lab-admin para 101 y 202 (subTest por expediente) · -k tc03
Oráculo	200 en ambos; datos exactos; expedientes intactos; dos eventos con usuario admin y sin token.
Observado	Ambas lecturas correctas en dos corridas limpias.
Resultado	**Aprobado** · Wilberth · wilberth_unidad_corrida1/2.txt

TC-04 · Estudiante intenta leer un expediente ajeno (ciclo TDD 1)

Identificación	TC-04 / SEC-01, SEC-05 / R-01 / alta
Objetivo	Impedir el acceso horizontal (IDOR) sin filtrar datos en la respuesta.
Precondiciones	Estado nuevo; Ana con sesión válida; 202 pertenece a Luis (nota 91).
Datos / pasos	leer_expediente(estado, 'lab-ana', '202') · -k tc04
Oráculo	403; respuesta sin id, estudiante, sede, nota ni el nombre 'luis'; expedientes intactos.
Observado	Versión base: 200 con el expediente de Luis (H-01). Tras la corrección: 403 sin datos y estado intacto.
Resultado	**Aprobado** · Wilberth · tdd1_registro.md, tdd1_*.txt/png, wilberth_unidad_corrida1/2.txt

TC-05 · Docente intenta leer un expediente de otra sede (HTTP manual)

Identificación	TC-05 / SEC-01, SEC-05 / R-01 / alta
Objetivo	Verificar por la API el aislamiento entre sedes en lectura.
Precondiciones	Servidor recién iniciado; María (Central); 202 de Pacífico.
Datos / pasos	1) GET 101 y 202 con lab-admin (estado antes). 2) curl.exe -i -H "Authorization: Bearer lab-maria"

	http://127.0.0.1:8765/expedientes/202. 3) Mismo GET con lab-pedro (control positivo). 4) GET 101 y 202 con lab-admin.
Oráculo	403 para María sin campos protegidos; 200 para Pedro; ambos expedientes iguales antes y después.
Observado	Antes de corregir: 200 con los datos de Luis (H-03). Después: 403 {"error": "Operación denegada"}, Pedro 200, estado intacto.
Resultado	**Aprobado** · Wilberth · wilberth_api_antes.txt, wilberth_api_despues.txt, verificacion_http_denegaciones.png

TC-06 · Docente intenta cambiar una nota de otra sede (HTTP manual)

Identificación	TC-06 / SEC-02, SEC-05 / R-02 / alta
Objetivo	Verificar por la API que no se modifica una nota de otra sede.
Precondiciones	Servidor recién iniciado; María (Central); 202 con nota 91.
Datos / pasos	GET 202 con admin; POST /expedientes/202/nota con lab-maria y {"nota":70}; GET 202 con admin.
Oráculo	403 sin campos protegidos; 202 conserva nota 91.
Observado	No ejecutado por HTTP. La revisión estática y una reproducción en la lógica confirman el defecto (200 y nota 70): H-06.
Resultado	**No ejecutado** · Pendiente (Jania), se espera fallido hasta corregir H-06

TC-07 · Estudiante y administrador intentan cambiar notas

Identificación	TC-07 / SEC-02, SEC-05 / R-02 / alta
Objetivo	Comprobar la separación de funciones: solo los docentes modifican notas.
Precondiciones	Estado nuevo por rol; 101 = 82; sesiones válidas de Ana y del administrador.
Datos / pasos	actualizar_nota con lab-ana y luego con lab-admin, nota 70 (subTest por rol) · -k tc07
Oráculo	403 para ambos roles; respuesta sin datos protegidos; expedientes intactos.
Observado	403 en ambos roles y estado intacto en dos corridas.

Resultado	**Aprobado** · Wilberth · wilberth_unidad_corrida1/2.txt

TC-08 · Sesión revocada, ausente o desconocida (ciclo TDD 2)

Identificación	TC-08 / SEC-03, SEC-05 / R-03 / alta
Objetivo	Garantizar que una sesión inválida no lee ni modifica.
Precondiciones	Estado nuevo por variante; sesión de María revocada; token vacío; token inexistente.
Datos / pasos	revocar_sesion; leer 101 y cambiar nota 101 a 70 con cada variante.
Oráculo	401 en todas las variantes; sin datos protegidos; expedientes intactos.
Observado	La prueba original de revocación obtiene 200 en lugar de 401 (H-02).
Resultado	**Fallido** · defecto del producto confirmado · TDD 2 pendiente (Jania)

TC-09 · Sesión expirada (HTTP manual)

Identificación	TC-09 / SEC-03, SEC-05 / R-03 / alta
Objetivo	Verificar por la API que lab-vencida no accede.
Precondiciones	Servidor nuevo; lab-vencida expirada; 101 = 82.
Datos / pasos	GET /expedientes/101 y POST /expedientes/101/nota {"nota":70} con Bearer lab-vencida; GET 101 con admin.
Oráculo	401 en ambas solicitudes; sin datos; nota 82 intacta.
Observado	—
Resultado	**No ejecutado** · Pendiente (Jania)

TC-10 · Límite inferior válido: nota 0 (integración HTTP)

Identificación	TC-10 / SEC-02, SEC-04, SEC-06 / R-02, R-04, R-05 / alta
Objetivo	Confirmar que la validación no rechaza el límite válido.
Precondiciones	Servidor de prueba iniciado por la propia prueba en un puerto local; María; 101 = 82.

Datos / pasos	POST /expedientes/101/nota {"nota":0}; GET posterior; cerrar servidor.
Oráculo	200; nota 0 persistida; evento de auditoría sin token.
Observado	—
Resultado	**No ejecutado** · Pendiente (Jania)

TC-11 · Límite superior válido: nota 100 (integración HTTP)

Identificación	TC-11 / SEC-02, SEC-04, SEC-06 / R-02, R-04, R-05 / alta
Objetivo	Confirmar que el límite superior inclusivo se acepta.
Precondiciones	Igual que TC-10.
Datos / pasos	POST /expedientes/101/nota {"nota":100}; GET posterior; cerrar servidor.
Oráculo	200; nota 100 persistida; auditoría sin token.
Observado	—
Resultado	**No ejecutado** · Pendiente (Jania)

TC-12 · Valores fuera de frontera y tipos inválidos (HTTP manual)

Identificación	TC-12 / SEC-04 / R-04 / alta
Objetivo	Rechazar los valores inmediatamente fuera de [0, 100] y los tipos inválidos sin persistir.
Precondiciones	Servidor reiniciado antes de cada variante; María; 101 = 82; 202 = 91.
Datos / pasos	Variantes: -1, 101, "ochenta", true y 1 seguido de 400 ceros (número JSON). El cuerpo se guarda en un archivo ASCII y se envía con curl.exe --data-binary; GET de 101 y 202 como admin antes y después.
Oráculo	400 por variante; ambos expedientes idénticos antes y después.
Observado	Antes de corregir: -1, 101, true y el entero enorme se aceptaban con 200 y persistían (H-04); "ochenta" ya devolvía 400. Después: las cinco variantes → 400 y estado intacto.
Resultado	**Aprobado** · Wilberth · wilberth_api_antes.txt, wilberth_api_despues.txt

5. Ciclos TDD rojo – verde – refactor

Cada ciclo conserva tres evidencias: (1) **ROJO**, la prueba falla por el motivo correcto; (2) **VERDE**, cambio mínimo y prueba aprobada; (3) **REFACTOR**, mejora de estructura con la suite nuevamente ejecutada. Se identifica el commit de cada paso y se mantiene la estructura de colores RGB.

5.1 Ciclo 1 · Acceso indebido a expediente ajeno (TC-04, SEC-01, H-01)

Fase	Commit	Qué se hizo	Comando y resultado	Evidencia
ROJO	4cf28d2	Se reforzó la prueba: copia profunda del estado, 403 esperado, ausencia de campos protegidos y estado intacto. No se tocó src/lab.py.	python -m unittest discover -s tests -k test_rojo_estudiante_no_consulta_expediente_ajeno -v → FAILED: AssertionError 403 != 200 (fallo de autorización, no de sintaxis ni importación)	tdd1_rojo.txt, tdd1_rojo.png, tdd1_rojo_cambios.patch
VERDE	e4cc9fc	Cambio mínimo en leer_expediente: si el usuario es estudiante y no es el titular, devolver 403 con mensaje genérico. El oráculo de la prueba no se modificó.	Mismo comando → Ran 1 test, OK (403, sin datos, estado intacto)	tdd1_verde.txt, tdd1_verde.png, tdd1_verde_cambios.patch
REFACTOR	9525e75	La condición se extrajo a una función privada sin cambiar el comportamiento. Luego se generalizó a _puede_leer (rol + sede) en 8e98b14.	-k estudiante -k docente → 3 pruebas OK (regresión relacionada). Suite completa → 3 OK y 1 fallo conocido (H-02).	tdd1_refactor.txt/.png, tdd1_refactor_cambios.patch, tdd1_suite_completa.txt/.png

El fallo de la suite completa durante el refactor corresponde a la sesión revocada (H-02, bloque de Jania). No se omitió ni se alteró esa prueba para aparentar una suite totalmente en verde. Las capturas de las tres fases están en el Anexo A y el resumen visual en evidencias/tdd1_resumen_rgb.html.

5.2 Ciclo 2 · Validez de sesión (TC-08, SEC-03, H-02) — Pendiente (Jania)

Fase	Plan
ROJO	Ampliar TC-08 con sesión revocada, token vacío y token inexistente, en lectura y escritura. Guardar la salida fallida (hoy 200 != 401).
VERDE	Cambio mínimo en autenticar(): devolver None si la sesión está revocada o expirada. Ejecutar TC-08 → OK.
REFACTOR	Extraer la verificación de validez de sesión y ejecutar la suite completa; registrar commit de cada fase.

6. Ejecución en laboratorio

6.1 Pruebas automatizadas

Comando de la suite completa (desde entrega/laboratorio_seguridad): python -m unittest discover -s tests -v. Comando del bloque de Wilberth: python -m unittest discover -s tests -k SeguridadWilberth -v. Entorno: Windows 11, Python 3.14.7, unittest. El estado limpio se garantiza con un proceso Python nuevo y setUp() por prueba.

Ejecución	Versión	Resultado	Evidencia
Línea base (ejemplos originales)	3a27a6f	4 pruebas: 2 OK, 2 fallidas (H-01, H-02)	ejecucion_inicial.txt
Pruebas ampliadas antes de corregir la auditoría	9525e75 + cambios	TC-01 y TC-03 fallan: el evento no identifica al usuario (H-05)	wilberth_unidad_antes.txt
Bloque Wilberth · corrida limpia 1	8e98b14 *	4/4 OK	wilberth_unidad_corrida1.txt
Bloque Wilberth · corrida limpia 2	8e98b14 *	4/4 OK	wilberth_unidad_corrida2.txt
Suite completa del equipo	8e98b14 *	6 pruebas: 5 OK, 1 fallo esperado (H-02)	suite_parcial_equipo.txt, verificacion_wilberth.png

* Las corridas se registraron antes de crear el commit 8e98b14. Los hashes SHA-256 de src/lab.py, tests/test_laboratorio.py y servidor.py guardados en version_bloque_wilberth.json coinciden con los archivos de ese commit, por lo que el código ejecutado es exactamente el versionado.

6.2 Pruebas manuales por la API

Caso	Tipo de prueba	Solicitud principal	Antes de corregir	Después de corregir
TC-05	Acceso entre sedes	GET /expedientes/202 · Bearer lab-maria	200 con datos de Luis	403 sin datos; Pedro 200; estado intacto
TC-12	Entrada inválida	POST /expedientes/101/nota · Bearer lab-maria · 5 variantes	4 variantes aceptadas y persistidas	5 variantes → 400; estado intacto
TC-06	Escritura entre sedes	POST /expedientes/202/nota · Bearer lab-maria	Pendiente (Jania)	—
TC-09	Sesión expirada	GET y POST con Bearer lab-vencida	Pendiente (Jania)	—

Cada variante se ejecutó con el servidor reiniciado para partir de datos limpios. Los registros wilberth_api_antes.txt y wilberth_api_despues.txt contienen los comandos exactos, los cabezales y los cuerpos de respuesta; las capturas verificacion_http_*.png muestran la repetición en la terminal de Wilberth.

6.3 Revisión estática del código (SAST manual)

La revisión estática examina el código **sin ejecutarlo** con una lista de comprobación; las solicitudes HTTP del apartado 6.2 son pruebas **dinámicas**. No se utilizó un escáner SAST ni DAST automatizado.

Comprobación	Hallazgo en el código	Estado / acción
Permisos de lectura	La versión base no aplicaba ninguna política tras autenticar.	Corregido: _puede_leer por rol, titular y sede (H-01, H-03).
Permisos de modificación	Solo verifica rol docente; no compara la sede del docente con la del expediente.	Abierto: H-06 (Jania).

Comprobación	Hallazgo en el código	Estado / acción
Validez de sesión	autenticar() ignora los indicadores revocada y expirada.	Abierto: H-02 (Jania).
Validación de entrada	Aceptaba bool y cualquier número sin rango.	Corregido: _nota_valida excluye bool y aplica [0, 100]; rechaza NaN e infinito (H-04).
Manejo de errores	Mensajes genéricos 401/403/400; no hay trazas internas en las respuestas.	Conforme.
Exposición de datos	Las denegaciones retornan antes de copiar el expediente.	Conforme; verificado en TC-04/05/07.
Auditoría	Los eventos guardaban el token y no el usuario.	Lectura corregida; actualización abierta (H-05, Jania).
Orden de controles	Se responde 404 antes de autorizar: un estudiante distingue ids existentes (403) de inexistentes (404).	Observación O-06, baja.
Estado compartido	ThreadingHTTPServer comparte un diccionario sin bloqueo.	Observación O-08, baja (fuera de alcance: concurrencia).

6.4 Corrección y regresión

Los defectos confirmados del bloque de Wilberth (H-01, H-03, H-04 y la parte de lectura de H-05) se corrigieron. Después de cada corrección se repitió la prueba que fallaba y se ejecutó la regresión de los casos relacionados: TC-04 tras el TDD 1; TC-01, TC-03, TC-04 y TC-07 en dos corridas; TC-05 y TC-12 por HTTP antes y después. Ninguna aserción se debilitó para obtener un resultado aprobado.

7. Revisiones, usabilidad y reproducibilidad

7.1 Acta de inspección cruzada — Pendiente (Jania)

Una persona distinta del autor revisa una política de acceso y dos casos de prueba. Jania revisará la política de lectura (_puede_leer) y los casos TC-01 y TC-04 de Wilberth; Wilberth revisará la política de escritura y dos casos de Jania.

Campo	Registro
Revisor / autor	Jania Hernández (revisora) / Wilberth Guillén (autor)
Fecha	[completar al realizar la inspección]
Objetos inspeccionados	Política de lectura _puede_leer · TC-01 · TC-04
Preguntas guía	¿La prueba comprueba el efecto sobre los datos? ¿Es independiente? ¿Puede fallar cuando el control falla?
Observaciones, severidad y acción	[confirmar o descartar las observaciones O-01 a O-08 y agregar las propias]

Observaciones verificables preparadas para la inspección:

ID	Objeto	Observación	Sev.	Acción tomada / propuesta
O-01	Prueba de consulta propia	El oráculo original solo verificaba 200 e identidad; no detectaba fallos de auditoría.	Media	Ampliado: respuesta completa, estado intacto y auditoría sin token (TC-01).
O-02	Prueba de acceso ajeno	assertNotIn('nota') no detectaba la filtración de otros campos.	Media	Ampliado: se comprueban id, estudiante, sede, nota y titular (TC-04).
O-03	Política de lectura	Docentes podían leer otras sedes.	Alta	Corregido con _puede_leer (H-03).
O-04	Sesiones	autenticar() no revisa revocada/expirada.	Alta	Abierto: H-02, TDD 2 de Jania.
O-05	Auditoría de escritura	actualizar_nota guarda el token y no el usuario.	Alta	Abierto: H-05 (escritura), Jania.
O-06	Orden de controles	404 antes de autorizar permite enumerar ids existentes.	Baja	Propuesta: autorizar antes o responder 403/404 uniforme.
O-07	Revocación	revocar_sesion acepta una sesión expirada (200).	Baja	Propuesta: responder 401 si la sesión ya no es válida.
O-08	Servidor	Estado compartido entre hilos sin bloqueo.	Baja	Se acepta como limitación del laboratorio.

7.2 Revisión de las propias pruebas

Prueba	¿Comprueba el efecto sobre los datos?	¿Es independiente?	¿Puede fallar si el control falla?
TC-01	Sí: compara todos los expedientes y el evento de auditoría	Sí: estado nuevo en setUp	Sí: falló cuando la auditoría no guardaba el usuario
TC-03	Sí: compara datos y dos eventos	Sí	Sí: falló por el mismo motivo que TC-01
TC-04	Sí: copia profunda antes/después	Sí	Sí: rojo demostrado (403 != 200)
TC-07	Sí: estado intacto por rol	Sí: estado nuevo por cada rol	Sí: si se quita la condición de rol, recibe 200

7.3 Usabilidad de los mensajes del control

Situación	Mensaje actual	Divulgación	Claridad y mejora
Sesión inválida (401)	{"error": "No autenticado"}	No revela datos ni si el token existió.	Claro pero no orienta. Propuesta: "Sesión no válida o vencida. Inicie sesión nuevamente." sin distinguir revocada/expirada.
Acceso denegado (403)	{"error": "Operación denegada"}	No revela titular, sede ni nota.	Genérico. Propuesta: "No tiene permiso para esta operación sobre el expediente solicitado." sin indicar el motivo exacto.

7.4 Ajustes para mantenimiento y diagnóstico

- test_estudiante_consulta_expediente_propio → test_tc01_sec01_estudiante_lee_su_expediente_sin_alterarlo: el nombre indica caso, requisito y comportamiento.
- test_rojo_estudiante_no_consulta_expediente_ajeno → test_tc04_sec01_estudiante_no_lee_expediente_ajeno_ni_filtra_datos, con mensaje "Ana no debe consultar el expediente 202 de Luis".

- Ayudantes reutilizables assertSinDatosProtegidos, assertExpedientesIntactos y assertLecturaAuditada con mensajes que nombran el campo o la condición que falla.

7.5 Prueba de reproducibilidad con el README — Pendiente (Jania)

Campo	Registro
Ejecutor	Jania Hernández (no es autora de la suite de Wilberth)
Fecha y entorno	[completar]
Procedimiento	Clonar, seguir solo README.md, ejecutar la suite, iniciar la API y restablecer datos
Resultado y dificultades	[completar con lo observado]
Cambios al README	[completar]

8. Registro de hallazgos

Detalle completo con pasos, versión, entorno y evidencia en hallazgos.csv. Entorno de todos los hallazgos: laboratorio local, Windows 11, Python 3.14.7, 25/10/2026.

ID	SEC / TC	Descripción (esperado / observado)	Sev.	Tratamiento	Estado
H-01	SEC-01 / TC-04	Estudiante lee un expediente ajeno (403 / 200 con datos)	Alta	Condición de titular (TDD 1)	Corregido y verificado
H-02	SEC-03 / TC-08	Sesión revocada sigue leyendo (401 / 200)	Alta	Validar revocada y expirada en autenticar()	Abierto (Jania)
H-03	SEC-01 / TC-05	Docente lee expediente de otra sede (403 / 200 con datos)	Alta	_puede_leer compara la sede	Corregido y verificado
H-04	SEC-04 / TC-12	Se persisten notas -1, 101, true y entero enorme (400 / 200)	Alta	_nota_valida (tipo y rango)	Corregido y verificado

ID	SEC / TC	Descripción (esperado / observado)	Sev.	Tratamiento	Estado
H-05	SEC-06 / TC-01, 02, 03	Auditoría guarda el token y no el usuario	Media	Lectura corregida; falta escritura	Abierto (parcial)
H-06	SEC-02 / TC-06	Docente cambia nota de otra sede (403 / 200 y nota modificada)	Alta	Comparar sede en actualizar_nota	Abierto (Jania)

8.1 Falsos positivos y fallos de la propia prueba

- El encabezado NativeCommandError de PowerShell en las capturas proviene de redirigir stderr con 2>&1; aparece incluso con resultados ok. Es un **falso positivo de la herramienta**, no un defecto del producto.
- Los fallos de TC-01 y TC-03 en wilberth_unidad_antes.txt son resultados del **producto** (auditoría sin usuario), no errores de la prueba: desaparecieron al corregir el código sin modificar las aserciones.
- En la versión base, las aserciones assertNotIn('nota', ...) de los ejemplos originales no llegaban a ejecutarse porque falla primero el código HTTP; por eso esa salida no se usó como prueba de ausencia de filtración (resultado **no concluyente**).

9. Indicadores, dictamen de liberación y riesgo residual

9.1 Estado consolidado de los 12 casos

Estado	Casos	Total
Aprobado	TC-01, TC-03, TC-04, TC-05, TC-07, TC-12	6
Fallido	TC-08	1
Bloqueado	—	0
No ejecutado	TC-02, TC-06, TC-09, TC-10, TC-11	5
Planificados		12

9.2 Indicadores calculados

Indicador	Fórmula	Cálculo	Valor
Tasa de aprobación	aprobados / (aprobados + fallidos) × 100	6 / (6 + 1) × 100	85.71 %

Indicador	Fórmula	Cálculo	Valor
Avance	(aprobados + fallidos) / planificados × 100	(6 + 1) / 12 × 100	58.33 %
Cobertura de requisitos	requisitos con ≥ 1 prueba válida / requisitos × 100	6 / 6 × 100	100 %

Cobertura: SEC-01 (TC-01, 03, 04, 05), SEC-02 (TC-07), SEC-03 (TC-08, prueba válida que falla y detecta H-02), SEC-04 (TC-12), SEC-05 (TC-04, 05, 07) y SEC-06 (TC-01, 03). La cobertura indica que cada requisito tiene al menos una prueba válida; no significa que todos los controles estén aprobados. Las métricas se calculan sobre casos, no sobre métodos de unittest ni variantes.

9.3 Dictamen

Decisión: NO LIBERAR.

Aunque la tasa de aprobación es 85.71 %, permanecen abiertos dos defectos críticos de seguridad: una sesión revocada conserva acceso (H-02) y un docente puede modificar notas de otra sede (H-06). Cualquiera de ellos por sí solo impide la liberación, porque compromete la confidencialidad y la integridad de los expedientes. Además, H-05 sigue abierto en la auditoría de actualizaciones y el 42 % de los casos aún no se ejecuta.

Condiciones para reevaluar (liberar con condiciones): corregir y verificar H-02, H-05 y H-06; ejecutar los 12 casos con dos corridas limpias completas; completar el TDD 2, la inspección cruzada y la prueba de reproducibilidad.

Responsable de la decisión hipotética: Wilberth Guillén Aguilar, como responsable de calidad del equipo (rol hipotético), con revisión de Jania Hernández. Fecha: 25/10/2026 (dictamen provisional).

9.4 Defectos abiertos, limitaciones y riesgo residual

- **Defectos abiertos:** H-02 (sesión revocada), H-05 (auditoría de escritura) y H-06 (escritura entre sedes).
- **Riesgo residual aceptable tras las correcciones:** enumeración de ids por 404 (O-06), revocación de sesiones ya expiradas (O-07) y estado sin bloqueo entre hilos (O-08), todos de severidad baja en un laboratorio local.
- **Limitaciones:** dos expedientes y cinco usuarios sintéticos; datos en memoria; sesiones simuladas sin tiempo real; tokens didácticos no aptos para producción; no se probaron carga, concurrencia ni DAST automatizado.
- Ningún resultado de este informe debe interpretarse como garantía de seguridad absoluta.

10. Aportes del equipo y uso de IA

Integrante	Aportes	Commits significativos
Wilberth Guillén	Base de la entrega, README, ciclo TDD 1, política de lectura, validación de notas, auditoría de lecturas, TC-01/03/04/05/07/12, revisión estática, matriz, hallazgos e informe	fb3fcde, 3a27a6f, 4cf28d2 (rojo), e4cc9fc (verde), 9525e75 (refactor), 8e98b14
Jania Hernández	Pendiente: TC-02/06/08/09/10/11, TDD 2, sesiones, escritura por sede, auditoría de escritura, integración HTTP, inspección cruzada y reproducibilidad	[completar]

El enunciado exige al menos dos commits significativos por integrante en dos días distintos. Los commits actuales de Wilberth son del 25/10/2026; el siguiente aporte debe registrarse en otra fecha.

Uso de IA: se utilizó un asistente de IA (Claude) para analizar el enunciado, proponer redacción de la documentación y apoyar la implementación y la ejecución de parte de las pruebas del bloque de Wilberth. Los registros de evidencia identifican qué ejecuciones fueron asistidas; Wilberth repitió las pruebas unitarias y HTTP en su terminal (capturas verificacion_*.png). El equipo revisó, ejecutó y comprende los resultados presentados.

Anexo A. Evidencias visuales

A.1 Ciclo TDD 1

ROJO · 4cf28d2

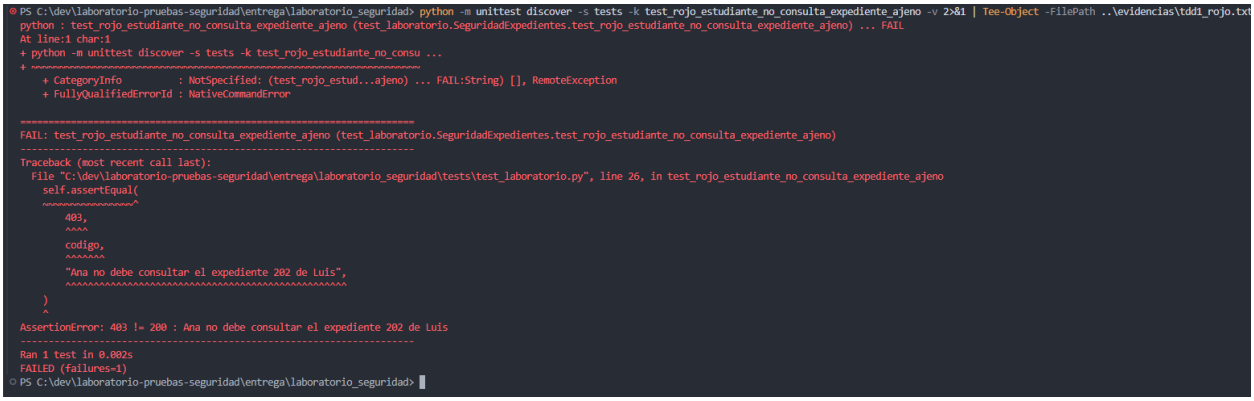


Figura 1. La prueba falla por la causa esperada: 403 esperado, 200 obtenido.

VERDE · e4cc9fc

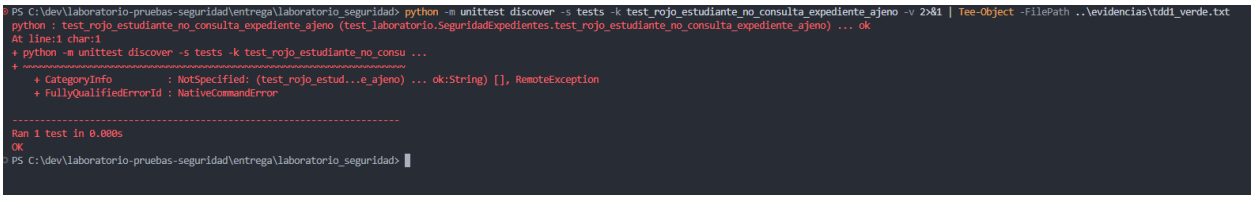


Figura 2. Tras el cambio mínimo la prueba aprueba.

REFACTOR · 9525e75

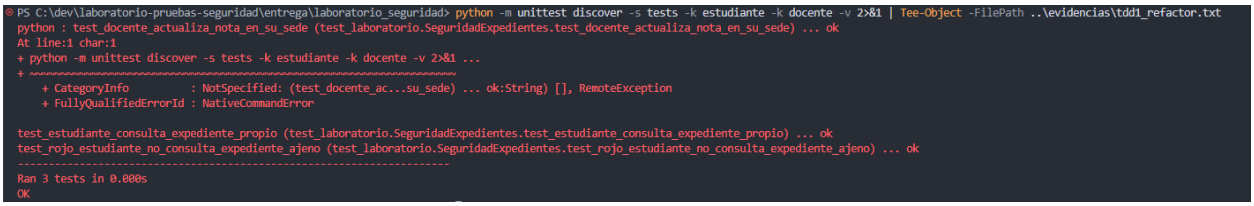


Figura 3. Regresión de las pruebas relacionadas tras el refactor.



Figura 4. Suite completa tras el refactor: único fallo conocido H-02.

A.2 Verificación del bloque y pruebas HTTP

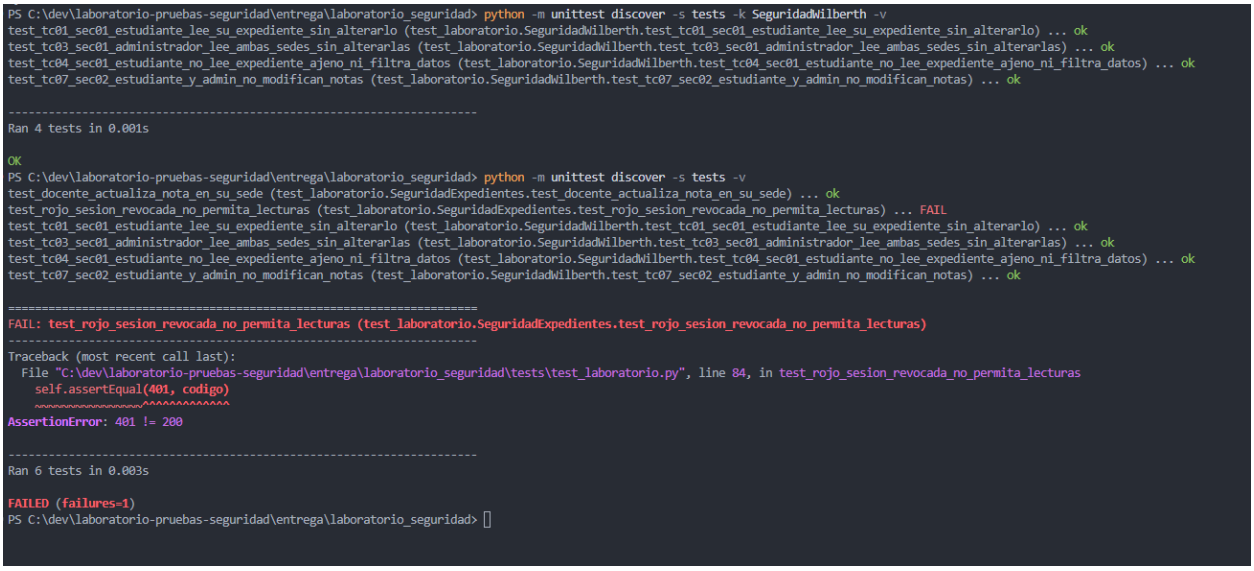


Figura 5. Bloque de Wilberth 4/4 OK y suite completa con el fallo esperado de sesión revocada.



Figura 6. TC-05: 403 entre sedes · TC-12: nota 101 rechazada con 400.

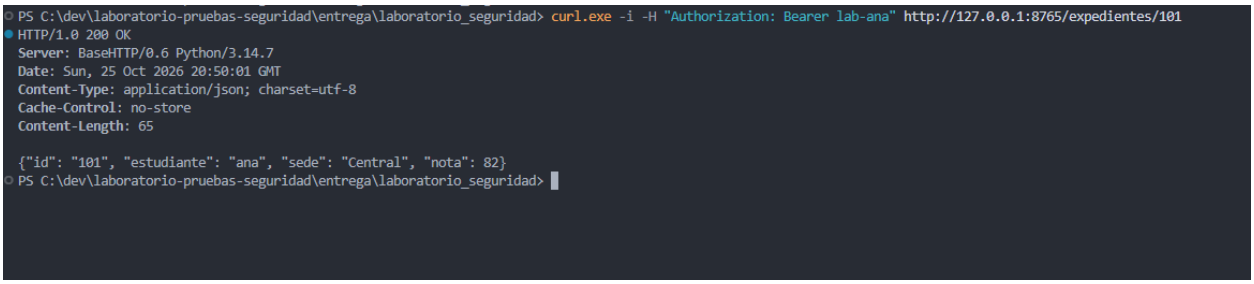


Figura 7. Consulta posterior: la nota del expediente 101 sigue en 82.

Anexo B. Índice de evidencias

Archivo (entrega/)	**Contenido**
matriz_trazabilidad.csv	Diseño completo de los 12 casos con estado y evidencia
hallazgos.csv	Registro H-01 a H-06 (plantilla A.2)
laboratorio_seguridad/README.md	Entorno, instalación, comandos y restablecimiento de datos
evidencias/ejecucion_inicial.txt	Línea base de los ejemplos originales
evidencias/tdd1_*	Rojo, verde, refactor y suite completa del TDD 1 (txt, png, patch)
evidencias/tdd1_registro.md · tdd1_resumen_rgb.html	Narrativa y resumen RGB del TDD 1
evidencias/wilberth_unidad_*.txt	Ejecución antes de corregir y dos corridas limpias
evidencias/wilberth_api_antes/despues.txt/.json	Pruebas HTTP TC-05 y TC-12 antes/después
evidencias/suite_parcial_equipo.txt	Suite completa del equipo en este corte
evidencias/revision_estatica.md	Lista de comprobación y observaciones O-01 a O-08
evidencias/version_bloque_wilberth.json	Hashes del código ejecutado (coinciden con 8e98b14)